

COMPLIANCE GAP ANALYSIS REPORT

GDPR Readiness Assessment — General Data Protection Regulation (EU) 2016/679

Company	TechStartup Pvt Ltd
Policy Analyzed	Privacy Policy v2.1 (August 2025)
Standard	GDPR — All 99 Articles, 11 Chapters
Analysis Date	6 August 2025
Generated By	ComplianceIQ Engine v1.0 — onetab.ai
Analyzed By	Agentic RAG Pipeline (4-Agent System)



Fully Met	12
Partially Met	9
Not Met	7
Conflicting	2
Total Requirements	30

RISK LEVEL: MEDIUM RISK — Action recommended

Max fine exposure: €20M or 4% annual revenue

Chapter-by-Chapter Breakdown

Ch	Chapter Name	Articles	Score	Status
1	General Provisions	Art. 1–4	—	Not Assessed
2	Principles	Art. 5–11	53.85%	Needs Improvement
3	Rights of the Data Subject	Art. 12–23	65.0%	Needs Improvement
4	Controller and Processor	Art. 24–43	42.86%	High Risk
5	Third Country Transfers	Art. 44–49	—	Not Assessed
6	Supervisory Authorities	Art. 51–59	—	Not Assessed
7	Cooperation & Consistency	Art. 60–76	—	Not Assessed
8	Remedies, Liability & Penalties	Art. 77–84	—	Not Assessed
9	Special Situations	Art. 85–91	—	Not Assessed
10	Delegated Acts	Art. 92–93	—	Not Assessed
11	Final Provisions	Art. 94–99	—	Not Assessed

This chapter is a critical gap area as it covers the fundamental principles of data processing, including lawfulness, fairness, and transparency, which are heavily scrutinized by regulators to ensure organizations are handling personal data in a lawful and ethical manner. Failure to fully meet these principles can lead to significant compliance risks and potential fines.

This chapter is a critical gap area as it covers the rights of data subjects, including access, rectification, and erasure, which are heavily scrutinized by regulators to ensure compliance with GDPR principles. Failure to fully meet these requirements can lead to significant fines and reputational damage, making it essential to address the partially met and unmet criteria.

This chapter is a critical gap area as it covers the responsibilities of controllers and processors under the GDPR, which is a key area of scrutiny for regulators, and the current state of compliance leaves significant room for improvement. Effective implementation of Articles 24–43 is essential to ensuring the proper handling of personal data and mitigating the risk of non-compliance.

Detailed Gap Analysis

5.1.a.1 · Art. 5(1)(a)

Fully Met Confidence: High (0.96)

GDPR Requires:

Personal data must be processed lawfully, fairly, and transparently.

Your Policy:

We process personal information lawfully, fairly and transparently.

Fix Required:

No action required.

5.1.b.1 · Art. 5(1)(b)

Fully Met Confidence: High (0.94)

GDPR Requires:

Data must be collected for specified, explicit, legitimate purposes and not further processed incompatibly.

Your Policy:

Personal information is collected for specified business purposes and is not used for unrelated purposes without appropriate authorization.

Fix Required:

No action required.

5.1.c.1 · Art. 5(1)(c)

Partially Met Confidence: High (0.91)

GDPR Requires:

Data collected must be adequate, relevant, and limited to what is necessary (data minimisation).

Your Policy:

We collect only information that is necessary to provide our services.

Analysis:

The policy evidence partially satisfies the requirement for data minimisation by stating that only necessary information is collected, but it lacks objective criteria or a documented process for determining data necessity. This gap undermines the effectiveness of the data minimisation principle. To fully meet the requirement, a clear process for evaluating data necessity must be established.

Fix Required:

Develop and document an objective criteria process for determining the necessity of collected data.

5.1.d.1 · Art. 5(1)(d)

Not Met Confidence: High (0.88)

GDPR Requires:

Personal data must be accurate and kept up to date.

Your Policy:

No matching evidence found in policy.

Analysis:

The policy does not meet the GDPR requirement for ensuring personal data accuracy and up-to-dateness, as no evidence or mechanism for maintaining data accuracy is provided. This significant gap puts the organisation at risk of non-compliance. Implementing a data validation and update process is essential.

Fix Required:

Establish a mechanism for regularly updating and verifying the accuracy of personal data.

5.1.e.1 · Art. 5(1)(e)

Partially Met Confidence: High (0.91)

GDPR Requires:

Data must be kept in identifiable form no longer than necessary (storage limitation).

Your Policy:

Personal information is retained for as long as necessary to fulfill the purposes for which it was collected.

Analysis:

The policy partially meets the storage limitation requirement by stating that personal information is retained as long as necessary, but it fails to provide a specific retention period or objective criteria for determining retention. This lack of specificity makes it difficult to ensure compliance. Defining clear retention periods or criteria is necessary.

Fix Required:

Define and document specific retention periods or objective retention criteria for personal data.

5.1.f.1 · Art. 5(1)(f)

Fully Met Confidence: High (0.95)

GDPR Requires:

Data must be processed with appropriate security, integrity and confidentiality.

Your Policy:

We implement appropriate technical and organizational safeguards to protect personal information.

Fix Required:

No action required.

6.1.a.1 · Art. 6(1)(a)

Fully Met Confidence: High (0.93)

GDPR Requires:

Processing requires a valid legal basis, e.g. freely given consent.

Your Policy:

Where required, we obtain consent before processing personal information.

Fix Required:

No action required.

6.1.b.1 · Art. 6(1)(b)

Partially Met Confidence: High (0.89)

GDPR Requires:

Processing may be based on necessity for performance of a contract.

Your Policy:

Certain information may be processed when necessary to perform our contractual obligations.

Analysis:

The policy partially satisfies the requirement for processing based on necessity for performance of a contract, as it mentions the legal basis but does not map it to specific processing activities. This gap means that the policy does not fully support compliance with the GDPR. Mapping the legal basis to specific activities will strengthen the policy.

Fix Required:

Map the legal basis for contractual necessity to specific processing activities in the policy.

6.1.c.1 · Art. 6(1)(c)

Not Met Confidence: High (0.86)

GDPR Requires:

Processing may be based on compliance with a legal obligation.

Your Policy:

No matching evidence found in policy.

Analysis:

The policy does not meet the GDPR requirement for processing based on compliance with a legal obligation, as no provision addressing this basis is identified. This significant omission must be addressed to ensure compliance. Adding a provision for legal obligation-based processing is necessary.

Fix Required:

Add a provision to the policy addressing processing based on compliance with legal obligations.

7.1.1 · Art. 7(1)

Fully Met Confidence: High (0.97)

GDPR Requires:

Consent requests must be clearly distinguishable, intelligible and easily accessible.

Your Policy:

Consent requests are presented separately from other terms and may be withdrawn at any time.

Fix Required:

No action required.

7.1.2 · Art. 7(3)

Partially Met Confidence: High (0.9)

GDPR Requires:

Data subject must be able to withdraw consent at any time, as easily as it was given.

Your Policy:

Users may withdraw consent by contacting our privacy team.

Analysis:

The policy partially meets the requirement for withdrawing consent, as it allows users to withdraw consent but does not ensure that this process is as easy as giving consent. This discrepancy must be addressed to fully comply with the GDPR. Ensuring equivalent ease in withdrawing and giving consent is essential.

Fix Required:

Revise the policy to ensure that the process for withdrawing consent is as easy as the process for giving consent.

8.1.1 · Art. 8(1)

Not Met Confidence: High (0.84)

GDPR Requires:

Where a child's consent applies, verifiable parental/guardian authorization is required.

Your Policy:

No matching evidence found in policy.

Analysis:

The policy does not meet the GDPR requirement for verifiable parental or guardian authorization for children's consent, as no mechanism for obtaining or verifying such authorization is specified. This gap must be filled to comply with the regulation. Implementing a parental authorization mechanism is necessary.

Fix Required:

Develop and implement a mechanism for obtaining and verifying parental or guardian authorization for children's consent.

9.1.1 · Art. 9(1)

Conflicting Confidence: High (0.87)

GDPR Requires:

Processing of special categories of personal data (health, biometric, etc.) is prohibited unless an exemption applies.

Your Policy:

We do not intentionally collect sensitive personal information.

Analysis:

The policy's stance on processing special categories of personal data is conflicting, which does not satisfy the GDPR requirement for prohibiting such processing unless an exemption applies. Clarifying the policy to consistently reflect compliance with the exemption criteria is necessary. Resolving these contradictions is essential for compliance.

Fix Required:

Revise the policy to consistently reflect compliance with the GDPR exemptions for processing special categories of personal data.

12.1.1 · Art. 12(1)

Fully Met Confidence: High (0.95)

GDPR Requires:

Information must be provided in a concise, transparent, intelligible, and easily accessible form, using plain language.

Your Policy:

This policy is written in clear and accessible language.

Fix Required:

No action required.

13.1.a.1 · Art. 13(1)(a)

Fully Met Confidence: High (0.96)

GDPR Requires:

The identity and contact details of the controller must be provided.

Your Policy:

ABC Ltd. is the controller responsible for your personal information. Our contact details are provided below.

Fix Required:

No action required.

13.1.c.1 · Art. 13(1)(c)

Partially Met Confidence: High (0.92)

GDPR Requires:

The purposes and legal basis of processing must be disclosed for each purpose.

Your Policy:

We use personal information to provide services, communicate with customers, and improve our products.

Analysis:

The policy evidence partially satisfies the requirement as it mentions the purposes of processing but fails to clearly map the legal basis to each purpose, leaving a noted gap in transparency.

Fix Required:

Add a section clearly mapping the legal basis to each processing purpose, such as 'Our legal basis for processing is [basis] for the purpose of [purpose].'

14.1.1 · Art. 14(1)

Not Met Confidence: High (0.83)

GDPR Requires:

Where data is not obtained from the subject, equivalent transparency information must be provided.

Your Policy:

No matching evidence found in policy.

Analysis:

The policy evidence does not satisfy the requirement as there is no mention of providing transparency information when data is not obtained from the subject, highlighting a significant gap in third-party data notification.

Fix Required:

Develop and document a third-party data notification process, including a description of how and when data subjects will be informed.

15.1.1 · Art. 15(1)

Fully Met Confidence: High (0.94)

GDPR Requires:

Data subject has the right to obtain confirmation and access to their personal data.

Your Policy:

You may request access to the personal information we hold about you by submitting a request to our privacy team.

Fix Required:

No action required.

16.1.1 · Art. 16

Fully Met Confidence: High (0.95)

GDPR Requires:

Data subject has the right to rectification of inaccurate personal data.

Your Policy:

You may request correction of inaccurate or incomplete personal information.

Fix Required:

No action required.

17.1.1 · Art. 17(1)

Partially Met Confidence: High (0.93)

GDPR Requires:

Data subject has the right to erasure ('right to be forgotten') without undue delay.

Your Policy:

You may request deletion of your account and associated personal information.

Analysis:

The policy evidence partially meets the requirement as it allows for the deletion of accounts and associated personal information but lacks clarity on the exceptions and conditions for erasure, creating uncertainty for data subjects.

Fix Required:

Expand the policy to clearly outline the applicable exceptions and conditions for erasure, such as 'Erasure will be performed without undue delay, except in cases where [exception].'

18.1.1 · Art. 18(1)

Not Met Confidence: High (0.89)

GDPR Requires:

Data subject has the right to obtain restriction of processing in specified circumstances.

Your Policy:

No matching evidence found in policy.

Analysis:

The policy evidence does not meet the requirement as it completely omits the right to obtain restriction of processing, leaving data subjects without a clear path to exercise this right.

Fix Required:

Add a 'Right to Restriction of Processing' section detailing the circumstances under which data subjects can request restriction and how such requests will be handled.

20.1.1 · Art. 20(1)

Partially Met Confidence: High (0.88)

GDPR Requires:

Data subject has the right to receive their data in a structured, machine-readable format (portability).

Your Policy:

Users may request a copy of the personal information associated with their account.

Analysis:

The policy evidence partially satisfies the requirement as it allows users to request a copy of their personal information but fails to specify the format and transmission requirements for data portability, limiting the effectiveness of this right.

Fix Required:

Enhance the policy to specify that personal data will be provided in a structured, machine-readable format, such as CSV, and describe the transmission method, ensuring compliance with data portability requirements.

21.1.1 · Art. 21(1)

Fully Met Confidence: High (0.93)

GDPR Requires:

Data subject has the right to object to processing based on legitimate interests, at any time.

Your Policy:

You may object to certain uses of your personal information by contacting our privacy team.

Fix Required:

No action required.

22.1.1 · Art. 22(1)

Conflicting Confidence: High (0.86)

GDPR Requires:

Data subject has the right not to be subject to a decision based solely on automated processing.

Your Policy:

We do not make decisions about individuals solely through automated means.

Analysis:

The policy evidence partially satisfies the requirement as it states that decisions are not made solely through automated means, but the noted gap indicates inconsistent statements regarding automated decision-making, which may lead to confusion. The policy needs to be clarified to ensure consistency. The current statement does provide some assurance that the right is respected, but the inconsistency must be addressed.

Fix Required:

Revise the policy to consistently state the approach to automated decision-making and ensure it aligns with GDPR requirements.

25.1.1 · Art. 25(1)

Partially Met Confidence: High (0.9)

GDPR Requires:

Controller must implement data protection by design and by default.

Your Policy:

Privacy and security considerations are taken into account when developing new systems.

Analysis:

The policy evidence partially meets the requirement as it mentions considering privacy and security when developing new systems, indicating some level of data protection by design and by default. However, the noted gap highlights the lack of documented processes or controls, which is crucial for fully implementing this principle. The current approach is insufficient for demonstrating full compliance.

Fix Required:

Develop and document a process for embedding data protection into system design, including specific controls and procedures.

30.1.1 · Art. 30(1)

Not Met Confidence: High (0.85)

GDPR Requires:

Controller must maintain a record of processing activities.

Your Policy:

No matching evidence found in policy.

Analysis:

The policy does not meet the requirement as there is no evidence found regarding the maintenance of a record of processing activities. This is a significant gap as it is a fundamental requirement for transparency and accountability. Without such records, it is impossible to demonstrate compliance with this aspect of the GDPR.

Fix Required:

Establish and document a record-of-processing-activities process, including what information is recorded and how it is maintained.

32.1.1 · Art. 32(1)

Fully Met Confidence: High (0.97)

GDPR Requires:

Controller must implement appropriate technical/organizational security measures.

Your Policy:

Personal information is protected using encryption, access controls, monitoring and other appropriate security measures.

Fix Required:

No action required.

33.1.1 · Art. 33(1)

Partially Met Confidence: High (0.92)

GDPR Requires:

A personal data breach must be notified to the supervisory authority within 72 hours.

Your Policy:

Personal data breaches must be reported to the privacy team promptly for assessment and response.

Analysis:

The policy partially meets the requirement as it mentions reporting personal data breaches to the privacy team for assessment and response, which implies some level of notification process. However, the noted gap indicates that the policy does not specify the deadline for notifying the supervisory authority, which is a critical component of breach notification under the GDPR. The policy must be updated to include this essential detail.

Fix Required:

Update the policy to explicitly state the 72-hour deadline for notifying the supervisory authority in the event of a personal data breach.

35.1.1 · Art. 35(1)

Fully Met Confidence: High (0.94)

GDPR Requires:

A Data Protection Impact Assessment (DPIA) is required for high-risk processing.

Your Policy:

High-risk processing activities undergo a privacy impact assessment before implementation.

Fix Required:

No action required.

36.1.1 · Art. 36(1)

Not Met Confidence: High (0.82)

GDPR Requires:

Prior consultation with the supervisory authority is required where a DPIA indicates high residual risk.

Your Policy:

No matching evidence found in policy.

Analysis:

The policy does not meet the requirement as there is no evidence of a procedure for prior consultation with the supervisory authority when a DPIA indicates high residual risk. This gap is significant because it undermines the ability to ensure that high-risk processing is adequately assessed and mitigated. The absence of such a procedure indicates a lack of preparedness for high-risk situations.

Fix Required:

Develop a procedure for prior consultation with the supervisory authority in cases where a DPIA indicates high residual risk, including criteria for when such consultation is required and the process for conducting it.

Priority Action Plan

P1 — CRITICAL PRIORITY · 9 items

#	Sub-ID	GDPR Article	Action Required	Current Status
1	5.1.d.1	Art. 5(1)(d)	Establish a mechanism for regularly updating and verifying the accuracy of personal data.	Not Met
2	6.1.c.1	Art. 6(1)(c)	Add a provision to the policy addressing processing based on compliance with legal obligations.	Not Met
3	8.1.1	Art. 8(1)	Develop and implement a mechanism for obtaining and verifying parental or guardian authorization for children's consent.	Not Met
4	9.1.1	Art. 9(1)	Revise the policy to consistently reflect compliance with the GDPR exemptions for processing special categories of personal data.	Conflicting
5	14.1.1	Art. 14(1)	Develop and document a third-party data notification process, including a description of how and when data subjects will be informed.	Not Met
6	18.1.1	Art. 18(1)	Add a 'Right to Restriction of Processing' section detailing the circumstances under which data subjects can request restriction and how such requests will be handled.	Not Met
7	22.1.1	Art. 22(1)	Revise the policy to consistently state the approach to automated decision-making and ensure it aligns with GDPR requirements.	Conflicting
8	30.1.1	Art. 30(1)	Establish and document a record-of-processing-activities process, including what information is recorded and how it is maintained.	Not Met
9	36.1.1	Art. 36(1)	Develop a procedure for prior consultation with the supervisory authority in cases where a DPIA indicates high residual risk, including criteria for when such consultation is required and the process for conducting it.	Not Met

P2 — HIGH PRIORITY · 9 items

#	Sub-ID	GDPR Article	Action Required	Current Status
1	5.1.c.1	Art. 5(1)(c)	Develop and document an objective criteria process for determining the necessity of collected data.	Partially Met
2	5.1.e.1	Art. 5(1)(e)	Define and document specific retention periods or objective retention criteria for personal data.	Partially Met
3	6.1.b.1	Art. 6(1)(b)	Map the legal basis for contractual necessity to specific processing activities in the policy.	Partially Met
4	7.1.2	Art. 7(3)	Revise the policy to ensure that the process for withdrawing consent is as easy as the process for giving consent.	Partially Met
5	13.1.c.1	Art. 13(1)(c)	Add a section clearly mapping the legal basis to each processing purpose, such as 'Our legal basis for processing is [basis] for the purpose of [purpose].'	Partially Met
6	17.1.1	Art. 17(1)	Expand the policy to clearly outline the applicable exceptions and conditions for erasure, such as 'Erasure will be performed without undue delay, except in cases where [exception].'	Partially Met
7	20.1.1	Art. 20(1)	Enhance the policy to specify that personal data will be provided in a structured, machine-readable format, such as CSV, and describe the transmission method, ensuring compliance with data portability requirements.	Partially Met
8	25.1.1	Art. 25(1)	Develop and document a process for embedding data protection into system design, including specific controls and procedures.	Partially Met
9	33.1.1	Art. 33(1)	Update the policy to explicitly state the 72-hour deadline for notifying the supervisory authority in the event of a personal data breach.	Partially Met

Executive Summary

TechStartup Pvt Ltd's overall GDPR compliance posture is at a medium risk level, with an overall score of 55.0% and 12 fully met, 9 partially met, 7 not met, and 2 conflicting requirements out of 30. The company's strongest area is Chapter 3 Rights of the Data Subject, with a score of 65.0%. However, critical gaps exist in several chapters, including the lack of a mechanism for regularly updating and verifying the accuracy of personal data, inadequate provisions for processing based on compliance with legal obligations, and insufficient procedures for obtaining and verifying parental or guardian authorization for children's consent. These gaps, particularly in areas such as data subject rights and controller and processor obligations, pose significant legal risks and require urgent remediation to mitigate potential penalties and reputational damage. The company must prioritize addressing these critical gaps, including developing and implementing mechanisms for obtaining and verifying parental or guardian authorization, revising policies to reflect compliance with GDPR exemptions, and establishing a record-of-processing-activities process. Prompt action is necessary to reduce the risk of non-compliance and ensure the protection of personal data.

DISCLAIMER: This report was generated by ComplianceIQ, an AI-powered compliance analysis tool developed by onetab.ai. It is intended for informational purposes only and does not constitute legal advice. ComplianceIQ uses Agentic RAG technology to map policy text against regulatory requirements and may not capture all nuances of legal interpretation. Organizations should consult qualified legal counsel before making compliance decisions. Confidence scores indicate retrieval quality, not legal certainty.